



AWS Security and Compliance

MODULE 6

BCSE355L – AWS SOLUTION ARCHITECT

Agenda

SECURITY AND COMPLIANCE
SHARED RESPONSIBILITY MODEL
AWS KMS
AWS WAF
AWS SHIELD
AWS SECURITY BEST PRACTICES

The background features a large, abstract, organic shape on the left side, composed of various shades of blue and purple, resembling a cluster of bubbles or a stylized cloud. This shape has several smaller, similar bubbles floating around it, particularly towards the bottom left. The rest of the background is a light, solid blue color.

Security and Compliance

Introduction

- Cloud security is the first priority at AWS.
- All AWS customers benefit from a data center and network architecture that is **built to satisfy the requirements of the most security-sensitive organizations**.
- AWS and its partners offer tools and features to help you meet your **security objectives around visibility, auditability, controllability, and agility**.
- This means that you can have the security you need, **but without the capital outlay and at a much lower operational overhead** than in an on-premises or a traditional data center environment.

Security and compliance

- Cloud security at AWS is the highest priority.
- As organizations embrace the scalability and flexibility of the cloud, AWS is helping them evolve security, identity, and compliance into key business enablers.
- AWS builds security into the core of our cloud infrastructure, and offers foundational services to help organizations meet their unique security requirements in the cloud.
- Security in the cloud is much like security in your on-premises data centers—only without the costs of maintaining facilities and hardware.
- In the cloud, you don't have to manage physical servers or storage devices.
- Instead, you use software-based security tools to monitor and protect the flow of information into and out of your cloud resources.

Security and compliance

- AWS Cloud is that it allows you to scale and innovate, while maintaining a secure environment and paying only for the services you use. This means that you can have the security you need at a lower cost than in an on-premises environment.
- As an AWS customer you inherit all the best practices of AWS policies, architecture, and operational processes built to satisfy the requirements of our most security-sensitive customers. Get the flexibility and agility you need in security controls.
- The AWS Cloud enables a shared responsibility model. While AWS manages security of the cloud, you are responsible for security in the cloud.
- This means that you retain control of the security you choose to implement to protect your own content, platform, applications, systems, and networks no differently than you would in an on-site data center.

Security and compliance

- AWS provides you with guidance and expertise through online resources, personnel, and partners. AWS provides you with advisories for current issues, plus you have the opportunity to work with AWS when you encounter security issues.
- You get access to hundreds of tools and features to help you to meet your security objectives.
- AWS provides security-specific tools and features across network security, configuration management, access control, and data encryption.
- Finally, AWS environments are continuously audited, with certifications from accreditation bodies across geographies and verticals. In the AWS environment, you can take advantage of automated tools for asset inventory and privileged access reporting.

Benefits of AWS security

- **Keep Your data safe** — The AWS infrastructure puts strong safeguards in place to help protect your privacy. All data is stored in highly secure AWS data centers.
- **Meet compliance requirements** — AWS manages dozens of compliance programs in its infrastructure. This means that segments of your compliance have already been completed.
- **Save money** — Cut costs by using AWS data centers. Maintain the highest standard of security without having to manage your own facility
- **Scale quickly** — Security scales with your AWS Cloud usage. No matter the size of your business, the AWS infrastructure is designed to keep your data safe.

Compliance

- AWS Cloud Compliance helps you understand the robust controls in place at AWS for security and data protection in the cloud.
- Compliance is a shared responsibility between AWS and the customer, and use the Shared Responsibility Model to learn more. Customers can feel confident in operating and building on top of the security controls AWS uses on its infrastructure.
- The IT infrastructure that AWS provides to its customers is designed and managed in alignment with best security practices and a variety of IT security standards.

Compliance

- The following is a partial list of assurance programs with which AWS complies:
 - SOC 1/ISAE 3402, SOC 2, SOC 3
 - FISMA, DIACAP, and FedRAMP
 - PCI DSS Level 1
 - ISO 9001, ISO 27001, ISO 27017, ISO 27018
- AWS provides customers a wide range of information on its IT control environment in whitepapers, reports, certifications, accreditations, and other third-party attestations.

Benefits of Compliance on AWS

- **Third-party validation for 1,000s of global requirements** - continually monitor to help you meet security and compliance standards for finance, retail, healthcare, government, and beyond.
- **Inherit the latest security controls AWS uses on its own infrastructure** - controls strengthen your own compliance and certification programs, while also receiving access to tools you can use to reduce your cost and time to run your own specific security assurance requirements.
- **Streamline and automate compliance** - Reduce risk and enable scale by using our activity monitoring services that detect configuration changes and security events across your system, even integrating our services with your existing solutions to simplify your operations and compliance reporting.

Benefits of Compliance on AWS

- **On-demand compliance reports** - Get on-demand access to AWS and ISV security and compliance reports by using AWS Artifact. Find auditor-issued reports, certifications, accreditations, and other third-party attestations of AWS in a comprehensive resource.

The background features a large, abstract, organic shape on the left side, rendered in shades of blue and purple with a soft gradient. This shape has several smaller, rounded protrusions. Scattered across the light blue background are numerous small, semi-transparent spheres in various sizes, also in shades of blue and purple, creating a bubbly, ethereal effect.

Shared Responsibility Model

Shared Responsibility Model

- Security and Compliance is a shared responsibility between AWS and the customer.
- This shared model **can help relieve the customer's operational burden as AWS operates, manages and controls the components from the host operating system and virtualization layer down to the physical security of the facilities in which the service operates.**
- The customer assumes responsibility and management of the guest operating system (including updates and security patches), other associated application software as well as the configuration of the AWS provided security group firewall.
- Customers should carefully consider the services they choose as their responsibilities vary depending on the services used, the integration of those services into their IT environment, and applicable laws and regulations.

Shared Responsibility Model

- The nature of this shared responsibility also provides the flexibility and customer control that permits the deployment.
- As shown in the chart below, this differentiation of responsibility is commonly referred to as Security “of” the Cloud versus Security “in” the Cloud.
- **AWS responsibility “Security of the Cloud”** - *responsible for protecting the infrastructure that runs all of the services* offered in the AWS Cloud. This infrastructure is composed of the **hardware, software, networking, and facilities** that run AWS Cloud services.

CUSTOMER

RESPONSIBILITY FOR
SECURITY 'IN' THE CLOUD

CUSTOMER DATA

PLATFORM, APPLICATIONS, IDENTITY & ACCESS MANAGEMENT

OPERATING SYSTEM, NETWORK & FIREWALL CONFIGURATION

CLIENT-SIDE DATA
ENCRYPTION & DATA INTEGRITY
AUTHENTICATION

SERVER-SIDE ENCRYPTION
(FILE SYSTEM AND/OR DATA)

NETWORKING TRAFFIC
PROTECTION (ENCRYPTION,
INTEGRITY, IDENTITY)

AWS

RESPONSIBILITY FOR
SECURITY 'OF' THE CLOUD

SOFTWARE

COMPUTE

STORAGE

DATABASE

NETWORKING

HARDWARE/AWS GLOBAL INFRASTRUCTURE

REGIONS

AVAILABILITY ZONES

EDGE LOCATIONS

Shared Responsibility Model

- **Customer responsibility** “**Security in the Cloud**” – Customer responsibility will be determined by the AWS Cloud services that a customer selects. **This determines the amount of configuration work the customer must perform** as part of their security responsibilities.
- This customer/AWS shared responsibility model also extends to IT controls.
- Just as the responsibility to operate the **IT environment is shared** between AWS and its customers, so is the management, operation and verification of IT controls shared.
- AWS can help **relieve customer burden of operating controls** by managing those controls associated with the physical infrastructure deployed in the AWS environment that may previously have been managed by the customer.

Shared Responsibility Model

- As every customer is deployed differently in AWS, customers can take advantage of shifting management of certain IT controls to AWS which results in a (new) distributed control environment.
- Customers can then use the AWS control and compliance documentation available to them to perform their control evaluation and verification procedures as required.
- Below are examples of controls that are managed by AWS, AWS Customers and/or both.
 - Inherited controls
 - Shared controls
 - Customer specific

Shared Responsibility Model

- Inherited Controls
 - Controls which a **customer fully inherits from AWS**.
 - Physical and Environmental controls
- Shared Controls
 - Controls which **apply to both the infrastructure layer and customer layers**, but in completely separate contexts or perspectives.
 - In a shared control, AWS provides the requirements for the infrastructure and the customer must provide their own control implementation within their use of AWS services. Examples include:
 - **Patch Management** – AWS is responsible for patching and fixing flaws within the infrastructure, but customers are responsible for patching their guest OS and applications.
 - **Configuration Management** – AWS maintains the configuration of its infrastructure devices, but a customer is responsible for configuring their own guest operating systems, databases, and applications.
 - **Awareness & Training** - AWS trains AWS employees, but a customer must train their own employees.

Shared Responsibility Model

- Customer Specific
 - Controls which are solely the responsibility of the customer based on the application they are deploying within AWS services. Examples include:
 - Service and Communications Protection or Zone Security which may require a customer to route or zone data within specific security environments.

The background features a large, abstract, organic shape on the left side, composed of various shades of blue and purple, resembling a cluster of bubbles or a stylized cloud. This shape has several smaller, similar bubbles floating around it, particularly towards the bottom left. The rest of the background is a light, pale blue gradient.

AWS KMS

AWS Key Management Service(AWS KMS)

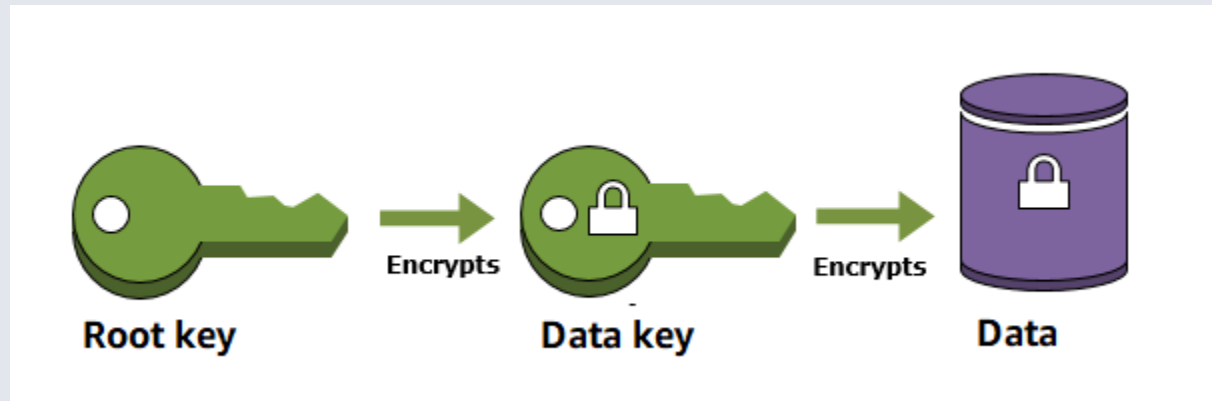
- AWS KMS is a managed service that makes it easy for you to create and control the encryption keys used to encrypt your data.
- AWS KMS lets you create keys that can never be exported from the service and that can be used to encrypt and decrypt data based on policies you define.
- By using AWS KMS, you gain more control over access to data you encrypt.
- You can use the key management and cryptographic features directly in your applications or through AWS cloud services that are integrated with AWS KMS.
- Whether you are writing applications for AWS or using AWS cloud services, AWS KMS enables you to maintain control over who can use your keys and gain access to your encrypted data.

AWS Key Management Service(AWS KMS)

- AWS Key Management Service (AWS KMS) is an AWS managed service that makes it easy for you to create and control the encryption keys that are used to encrypt your data.
- The AWS KMS keys that you create in AWS KMS are protected by FIPS 140-2 validated hardware security modules (HSM).
- They never leave AWS KMS unencrypted.
- To use or manage your KMS keys, you interact with AWS KMS.

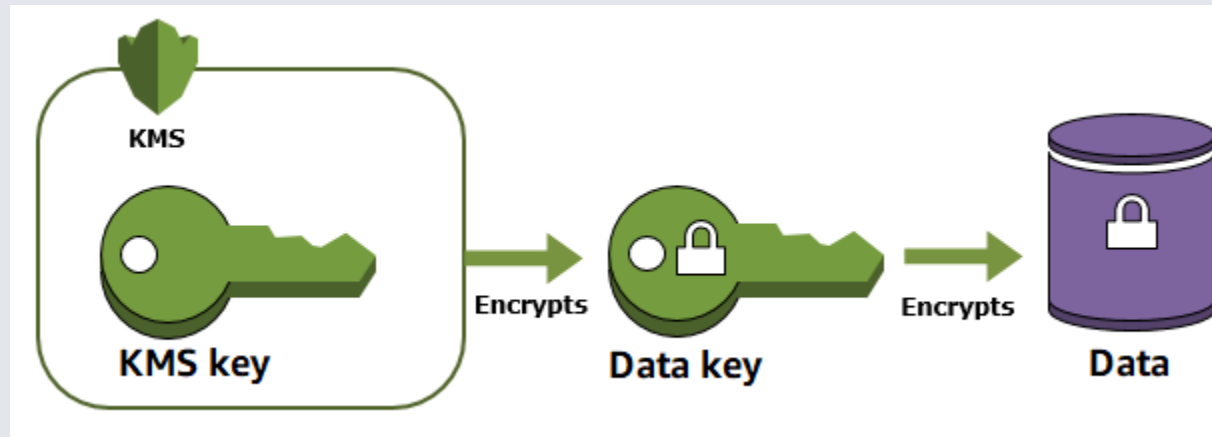
AWS Key Management Service(AWS KMS)

- Why use AWS KMS?
 - When you encrypt data, you need to protect your encryption key. If you encrypt your key, you need to protect its encryption key. Eventually, you must protect the highest level encryption key (known as a **root key**) in the hierarchy that protects your data. That's where AWS KMS comes in.



AWS Key Management Service(AWS KMS)

- Why use AWS KMS?
 - **AWS KMS protects your root keys.** KMS keys are created, managed, used, and deleted entirely within AWS KMS. They never leave the service unencrypted. To use or manage your KMS keys, you call AWS KMS.



AWS KMS key management

- Types of AWS KMS keys to encrypt your DB instances.
- Customer Managed Keys
 - AWS KMS uses a type of key called a **Customer Master Key (CMK)** to encrypt and decrypt data.
 - CMKs **are the fundamental resources** that AWS KMS manages.
 - They can be **used inside of AWS KMS** to encrypt or decrypt **up to 4 KB of data directly**.
 - They can also be **used to encrypt generated data keys** that are then used to encrypt or decrypt larger amounts of data outside of the service.
 - **CMKs can never leave AWS KMS unencrypted**, but **data keys can leave the service unencrypted**.

AWS KMS key management

- Data Keys
 - Use data keys to encrypt large data objects within your own application outside AWS KMS.
 - When calling `GenerateDataKey`, AWS KMS returns a plaintext version of the key and ciphertext that contains the key encrypted under the specified CMK.
 - AWS KMS tracks which CMK was used to encrypt the data key.
 - Use the plaintext data key in your application to encrypt data, and you typically store the encrypted key alongside your encrypted data.
 - Should always remove the plaintext key from memory as soon as is practical after use.
 - To decrypt data in your application, pass the encrypted data key to the `Decrypt` function.
 - AWS KMS uses the associated CMK to decrypt and retrieve your plaintext data key. Use the plaintext key to decrypt your data, and then remove the key from memory.

AWS KMS key management

- Envelope Encryption
 - AWS KMS uses envelope encryption to protect data.
 - AWS KMS creates a data key, encrypts it under a CMK, and returns plaintext and encrypted versions of the data key to you.
 - Use the plaintext key to encrypt data and store the encrypted key alongside the encrypted data.
 - The key should be removed from memory as soon as is practical after use.
 - Can retrieve a plaintext data key only if you have the encrypted data key and you have permission to use the corresponding master key.

AWS KMS key management

- Encryption Context
 - All AWS KMS cryptographic operations accept an **optional key/value map of additional contextual information** called an **encryption context**.
 - The specified context must be the **same for both the encrypt and decrypt operations** or decryption will not succeed.
 - The encryption context **is logged, can be used for additional auditing**, and is available as context in the AWS policy language for fine-grained policy-based authorization.

AWS KMS Benefits

- Manage keys and define policies from a single point
 - Centrally manage keys and define policies across integrated services and applications from a single point.
- Encrypt data within your applications
 - Encrypt data within your applications with the AWS Encryption SDK data encryption library.
- Perform signing operations
 - Perform signing operations using asymmetric key pairs to validate digital signatures.
- Securely generate HMACs
 - Securely generate **hash-based message authentication codes (HMACs)** that ensure message integrity and authenticity.

AWS KMS Use cases

- Protect your data at rest
 - Activate server-side encryption with AWS KMS using KMS keys that you control and manage.
- Encrypt and decrypt data
 - Use the AWS Encryption SDK to securely handle cryptographic operations in your applications.
- Sign and verify digital signatures
 - Protect signing operations with AWS KMS using asymmetric KMS keys.
- Build secure multi-tenant databases
 - Use the AWS Database Encryption SDK to easily encrypt and securely search sensitive records in your databases.

The background features a large, abstract, organic shape on the left side, composed of various shades of blue and purple, resembling a cluster of bubbles or a stylized cloud. This shape has several smaller, similar bubbles of varying sizes floating around it, particularly towards the bottom left and right. The rest of the background is a light, pale blue gradient.

AWS WAF

AWS Web Application Firewall (WAF)

- AWS Web Application Firewall (WAF), as the name implies, is a **firewall for your web applications**.
- It can create a layer of protection around your web applications and **RESTful APIs**.
- It **guards against the most well-known web exploits**.
- AWS WAF can be **used to control network traffic** - controlled by **creating rules**. These rules can target well-known exploits such as SQL injections or XSS attacks.
- Rules can be **customized to filter transactions** that meet user-defined patterns.
- AWS WAF has **Managed Rules**, which simplifies management. AWS can manage these rules, and AWS Marketplace sellers also offer preconfigured rules. AWS and Marketplace rules are constantly modified as new threats are identified.

AWS Web Application Firewall (WAF)

- AWS WAF also provides an API to assist in developing, deploying, and maintaining these security rules.
- AWS WAF can be deployed on the following:
 - Amazon CloudFront
 - Application Load Balancer
 - Origin servers running on EC2
 - Amazon API Gateway
 - AWS AppSync
- AWS WAF pricing depends on the number of rules deployed and the number of requests that applications receive.
- [https:// aws.amazon.com/waf/](https://aws.amazon.com/waf/).

The background features a collection of soft, 3D-rendered bubbles in various shades of blue and purple. These bubbles are of different sizes and are scattered across the frame, with a higher concentration on the left side. The overall aesthetic is clean, modern, and tech-oriented.

AWS Firewall Manager

AWS Firewall Manager

- AWS Firewall Manager makes setting up firewalls simple. It enables users to administer firewall rules in a central dashboard.
- This can be achieved even across multiple AWS accounts and applications.
- Cloud environments are dynamic. This can create maintenance headaches as new applications come online.
- AWS Firewall Manager simplifies the process of provisioning new applications and ensuring they comply with an enterprise's security policies by enabling users to manage firewall settings from one location.

AWS Firewall Manager

- If new security rules need to be created or if existing rules need to be modified, they can also be **changed only once**.
- Some of the services in AWS that can benefit from AWS Firewall Manager are the following:
 - Application Load Balancer
 - API Gateway
 - Amazon CloudFront distributions
 - Amazon EC2
- AWS Firewall Manager **allows adding AWS WAF rules, AWS Shield Advanced protection, security groups, and AWS Network Firewall rules to VPCs across accounts and resources using a centralized dashboard.**
- <https://aws.amazon.com/firewall-manager/>

The background features a collection of soft, 3D-rendered bubbles in various shades of blue and purple. These bubbles are of different sizes and are scattered across the frame, with a higher concentration on the left side. The overall aesthetic is clean, modern, and tech-oriented.

AWS Shield

AWS Shield

- AWS Shield is an **AWS-managed DDoS protection service** used to protect systems and data.
- AWS Shield **delivers automatic attack detection and resolution that can keep your application running, or at least reduce the amount of downtime.**
- AWS Shield Standard comes with all AWS accounts, you normally **have to contact AWS support to assist you if you suffer a DDoS attack.**
- AWS Shield comes in two flavors:
 - **AWS Shield Standard:** Provided at no additional charge to all AWS customers
 - **AWS Shield Advanced:** Provides a higher level of protection but at an additional cost

AWS Shield

- AWS Shield Standard can protect against and handle the more common types of attacks.
- The more common DDoS attacks happen at the network and transport layer.
- AWS Shield Standard can help you protect Amazon CloudFront and Amazon Route S3 against (Layer 3 and Layer 4) attacks.
- AWS Shield Advanced provides higher protection for more services. AWS Shield Advanced can be used to defend against attacks targeting the following:
 - Amazon EC2 instances
 - Elastic Load Balancing
 - Amazon CloudFront
 - AWS Global Accelerator
 - Amazon Route 53

AWS Shield

- AWS Shield Advanced not only protects against network and transport layer attacks, but also **delivers additional monitoring and resolution, protecting against large and sophisticated DDoS attacks and providing real-time reporting when attacks occur.**
- It **integrates with AWS WAF.**
- AWS Shield Advanced provides 24-hour support from AWS's DDoS response team as an additional feature.
- Finally, with AWS Shield Advanced, AWS will **cover any charges your account incurs for certain services that can be attributed to an attack.**
- <https://aws.amazon.com/shield/>

The background features a collection of soft, 3D-rendered bubbles in various shades of blue and purple. These bubbles are of different sizes and are scattered across the frame, with a higher concentration on the left side. The overall aesthetic is clean, modern, and visually appealing.

Security Best Practice

AWS Security Best Practices

- One quick thing before we get started: As you can tell from their name, AWS loves acronyms. This can create some confusion on what various AWS services do, so here's a quick breakdown:
- S3 (Simple Storage Service) = Object Storage
- EC2 (Elastic Compute Cloud) instance = Virtual machine/server
- AMI (Amazon Machine Image) = A machine image that contains an operating system and sometimes additional software that's run on an EC2 instance.
- VPC (Virtual Private Cloud) = Virtual network that closely resembles the network of a traditional data center. All modern EC2 instances run inside a VPC.

AWS Security Best Practices

- Plan ahead
- Embrace the cloud
- Define a security baseline for your AWS environment
- Enforce your baseline
- Limit access
- Watch for vulnerabilities
- Collect and protect logs
- Monitor, detect and react
- Unify AWS with on-premises and other cloud security
- Automate

AWS Security Best Practices

- Plan ahead
 - Thinking through how you will secure your AWS environment before you begin adopting it
- Embrace the cloud
 - Try to make the cloud mimic the on-premises environments they are used to protecting by doing things like prohibiting developers from making infrastructure changes.
 - Recognize that potentially risky aspects of the cloud, such as the rapid rate of change and the ease of deployment.
- Define a security baseline for your AWS environment
 - Security and DevOps teams should work together to describe everything from how assets must be configured to an incident response plan.
 - Consider the AWS Well-Architected Framework and the CIS Benchmarks for security.
 - Reevaluate your baseline at least every six months to incorporate things like new threats and changes in your environment.

AWS Security Best Practices

- Enforce your baseline
 - AWS Security Hub, but several third-party vulnerability management solutions include built-in monitoring for cloud misconfigurations.
 - For enforcing your security baseline is **a Cloud Security Posture Management (CSPM)** solution.
 - A quality CSPM will have the **ability to monitor accounts from multiple cloud providers for misconfigurations**.
 - This is a big deal, as it allows your organization to **set one security baseline for all your cloud providers**, then enforce it using a single tool.
 - CSPM include the **ability to flag issues in infrastructure as code before anything is deployed, IAM governance** (see the next section for more on IAM), **and compliance auditing**.

AWS Security Best Practices

- Limit access
 - To creating a secure AWS environment than restricting access to just those users and systems that need it. This is accomplished using AWS Identity Access Management (IAM).
 - **Don't use the root user:** The root user is the user that is associated with the email address used to create an AWS account. The root user can do things even a full admin cannot.
 - **Manage users through federated SSO:** It's a security best practice to use federated SSO to manage employee access to resources, and that includes AWS.
 - **Don't attach policies to individual users:** Instead, apply them to groups and roles.
 - **Require a strong password:** You should configure IAM to require a strong password - expire at least every 90 days and that previous passwords cannot be reused.

AWS Security Best Practices

- Limit access
 - **Require MFA:** Along with a strong password, you should ensure that all users have enabled MFA.
 - **Delete unused credentials:** IAM can generate a credentials report that shows when credentials for each user were last used. You should regularly go into this report and disable or delete credentials that haven't been used in the past 90 days.
 - **Regularly rotate access keys:** In many cases, you can (and should) use IAM roles instead of access keys for programmatic access to AWS. In those situations where you have to use access keys, you should make sure they are rotated at least every 90 days.

AWS Security Best Practices

- Watch for vulnerabilities
 - To detect vulnerabilities in EC2 instances, you can use AWS Inspector or a third-party vulnerability management solution.
- Collect and protect logs
 - Should log all activity that has occurred in your AWS environment. In AWS, most logs are captured using CloudTrail. This service **automatically captures and stores AWS API activity** as what AWS calls Management Events in your AWS account for no charge (although you will need to pay the cost of storage). Best practices for setting up CloudTrail in your AWS account:
 - **Create a trail for all regions**
 - **Protect the S3 bucket holding your logs**
 - **Encrypt the log files with SSE-KMS**
 - **Use log Validation**

AWS Security Best Practices

- Monitor, detect and react
 - A good SIEM will also provide a host of other features to **enhance your security team's ability to detect, confirm, and respond to an attack**. For example, the most advanced SIEMs use multiple techniques to detect suspicious behavior.
 - AWS and third-party tools to secure their AWS environment, in which case it's important to find a SIEM that includes a GuardDuty integration.
- Unify AWS with on-premises and other cloud security
 - Use different security solutions for each environment, it increases the likelihood of there being blind spots. In addition, the more tools your security team uses, the higher their workload, as they are forced to constantly bounce between tools in order to manually piece together a complete picture of the organization's current cybersecurity posture.

AWS Security Best Practices

- Automate
 - Best practices for securing AWS, it's **not reasonable to expect everyone to remember them all**.
 - Even if they did, mistakes happen. To ensure your AWS environment continuously adheres to your security baseline, you should turn to automation.
 - Another benefit of using automation is **the capacity it frees up within your security team**.
 - The ongoing shortage of security professionals means teams are overtaxed.

The background features several abstract, 3D-rendered shapes in shades of blue and purple. These include spheres of various sizes and larger, more complex organic forms. The shapes are distributed across the frame, with a notable cluster of larger, more intricate shapes on the right side. The overall aesthetic is modern and clean.

Thank you

BCSE355L – AWS SOLUTION
ARCHITECT
MODULE 6